

docs/modules/user-roles.md

## Фойдаланувчи роллари ва рухсатлар - СПЕС (ТАСДИҚЛАНГАН)

Фойдаланувчи тасдиги: АСОСИЙ ҚИСМ бажарилади (шу спец тўлиқ); «2-босқич» бўлими кейинчалик алоҳида келишилади. Иш картаси: Arbitr-092 (ёпилган - done/archived/; docs/review-log.md ёзуви ҳам бор).

### Мақсад

Эски 3 та қўпол роль (ADMIN/ACCOUNTANT/VIEWER) ўрнига соҳага асосланган 8 роллик тизим: ҳар фойдаланувчи фақат ўз ишига тегишли модулларни кўради/ўзгартиради. Фойдаланувчи талаби (манба: эски ERP лойиҳасидаги roles.md - репо ташқарисида; талаблар тўлиқ шу файлга кўчирилган, user-roles.md ўзи КАНОНИК; QBO'га мос бўлмаган қисмлар фойдаланувчи кўрсатмаси билан ОЛИБ ТАШЛАНДИ - қуйида). Бу аллақачон режалаштирилган эди - `UserRole` enum изоҳи: «Рухсатлар кейинги босқичларда майдалашади (QBO'даги роль тизими каби)».

Эталон изоҳи: QBO роль тизими Finance.xsd'да ЭМАС (product/preference хусусияти - entity эмас), шунинг учун qbo-reference'дан цитата йўқ - мослик QBO маҳсулот хулқига қараб белгиланади.

### QBO билан мослик харитаси (ҳар роль солиштирилган)

| Бизники           | QBO аналог                                                   |
|-------------------|--------------------------------------------------------------|
| SUPER_ADMIN       | Primary/Company admin                                        |
| CHIEF_ACCOUNTANT  | Standard user - All access (+ бухгалтерия ядроси)            |
| ACCOUNTANT        | QBO Advanced custom role (кундалик ҳужжат киритувчи, GL'сиз) |
| SALES_MANAGER     | Standard user - Limited: Customers & Sales                   |
| PURCHASE_MANAGER  | Standard user - Limited: Vendors & Purchases                 |
| WAREHOUSE_MANAGER | QBO'да ЙЎҚ - рухсат этилган фарқ №1 (multi-warehouse) остида |
| DIRECTOR_ADMIN    | QBO Advanced custom role (кенг view-only)                    |
| VIEWER_AUDITOR    | Reports only                                                 |

PAYROLL соҳаси - рухсат этилган фарқ №2 (Payroll Lite) остида.

#### ОЛИБ ТАШЛАНДИ (QBO'да йўқ - фойдаланувчи кўрсатмаси):

- CASHIER** роли (POS/terminal/кунлик касса ёпиш билан бирга) - QBO ядросида на POS, на кассир роли бор; иккита рухсат этилган фарқимизга кирмайди. Нақд операциялар CHIEF/ACCOUNTANT'нинг BANKING соҳаси орқали қилинади. Қайтиши фақат фойдаланувчи УЧИНЧИ онгли фарқ деб қарор қилса.
- Ҳужжат approve оқими** (DIRECTOR «approve қилади» банди) - QBO ядросида йўқ, DIRECTOR = кенг кўриш + назорат холос.
- Филиал (branch)** - QBO ядросида йўқ (Location tracking бошқа тушунча - у ҳам бизда йўқ).

### Қабул қилинган қарорлар

- Қатъий роль тўплами** (8 роль) - лекин остида permission модели билан, кейин QBO Advanced услубидаги per-user созлашга қайта ёзувсиз йўл очиқ.
- DIRECTOR\_ADMIN амалда VIEWER\_AUDITOR + EXPORT доим + бизнес эгаси семантикаси - approval оқими (агар фойдаланувчи QBO Advanced даражасини истаса) келгусида уни фарқлайди.

Боғлиқ: [[user-management.md]] (AppUser/UserService/login оқими - ЎЗГАРМАЙДИ, фақат роль тўплами кенгаяди), [[audit-log.md]] (роль ўзгариши USER\_UPDATED'да кўринади).

### Permission (соҳа) модели

Ҳар роль - соҳалар устидаги рухсатлар ТЎПЛАМИ (кодда матрица, DB жадвал ЭМАС - v1 қатъий тўплам). Рухсат рольга эмас, СОҲАга текширилади - янги роль қўшиш SecurityConfig'ни ўзгартирмайди.

Соҳалар ( `Permission` enum, area × даража):

| Соҳа        | Қамрови                                                                                               |
|-------------|-------------------------------------------------------------------------------------------------------|
| SALES       | мижозлар, invoice, estimate, sales receipt, CM, RR, мижоз тўлови, AR                                  |
| PURCHASE    | таъминотчилар, PO, bill, expense, VC, landed cost, тўлов, AP                                          |
| INVENTORY   | товарлар, категория, омбор ҳаракати, transfer, adjustment, count, омбор/бирлик/прайс каталоги         |
| BANKING     | банк транзакциялари, нақд кирим-чиқим, ўтказма, солиштириш                                            |
| GL          | счётлар режаси, қўлда JournalEntry, POSTED ҳужжат кўриниши                                            |
| PAYROLL     | ходимлар, иш ҳақи гуп/тўлов, ведомость                                                                |
| FIN_REPORTS | молиявий ҳисоботлар: P&L, Balance Sheet, Trial Balance, Cash Flow, солиқ                              |
| SETTINGS    | компания созламалари, солиқ ставкалари, тўлов усуллари, класслар, валюта, Excel import, factory reset |
| USERS       | фойдаланувчилар, роллар, аудит журнали                                                                |

Даража: `NONE` < `VIEW` < `EDIT` (EDIT доим VIEW'ни ўз ичига олади).

Алоҳида имкониятлар (boolean capability):

- **PERIOD\_CLOSE** - closing date очиш/ёпиш (GL'дан ажратилган: CHIEF'да бор, ACCOUNTANT'да йўқ);
- **EXPORT** - ҳисоботни экспорт қилиш (VIEWER'да ихтиёрий).

Роль → рухсат матрицаси

E = EDIT (ёзиш+кўриш), V = VIEW (фақат кўриш), - = NONE, `` = имконият.

| Соҳа/<br>ИМКОНИЯТ | SUPER_ADMIN | DIRECTOR_ADMIN | CHIEF_ACCOUNTANT | ACCOUNTANT | SALES_MANAGER | PURCHASE_MANAGER | WAREHOUSE_MANAGER | VIEWER_A |
|-------------------|-------------|----------------|------------------|------------|---------------|------------------|-------------------|----------|
| SALES             | E           | V              | E                | E          | E             | -                | -                 | V        |
| PURCHASE          | E           | V              | E                | E          | -             | E                | -                 | V        |
| INVENTORY         | E           | V              | E                | V          | -             | V                | E                 | V        |
| BANKING           | E           | V              | E                | E          | -             | -                | -                 | V        |
| GL                | E           | V              | E                | -          | -             | -                | -                 | V        |
| PAYROLL           | E           | V              | E                | -          | -             | -                | -                 | V        |
| FIN_REPORTS       | E           | V              | V                | -          | -             | -                | -                 | V        |
| SETTINGS          | E           | -              | -                | -          | -             | -                | -                 | -        |
| USERS             | E           | -              | -                | -          | -             | -                | -                 | -        |
| PERIOD_CLOSE      |             | -              |                  | -          | -             | -                | -                 | -        |
| EXPORT            |             |                |                  |            |               |                  |                   | ИХТ.     |

Изоҳлар:

- **Соҳа ҳисоботлари FIN\_REPORTS'дан алоҳида:** sales manager «сотув ҳисоботи»ни SALES VIEW орқали кўради (AR aging = sales), purchase manager AP aging'ни PURCHASE орқали, warehouse stock reports'ни INVENTORY орқали. FIN\_REPORTS фақат умумий молиявий ҳисоботлар (P&L/BS/TB/CF/солиқ).
- **PAYROLL** - бухгалтерия иши сифатида CHIEF\_ACCOUNTANT + SUPER\_ADMIN'да EDIT, DIRECTOR/VIEWER'да VIEW, қолганларда NONE.
- **DEACTIVATED admin ҳимояси** (BR-USR-007) энди SUPER\_ADMIN'га тегишли: тизимда камида битта фаол SUPER\_ADMIN қолиши шарт.

Ҳимоя (enforcement)

Уч қатлам, ҳаммаси server ҳақиқати:

1. **SecurityConfig - URL → соҳа** ( **hasAuthority** permission билан, рольга ЭМАС). Модул namespace'лари тоза: - SALES: **/invoices** , **/invoice-payments** , **/estimates** , **/credit-memos** , **/refund-receipts** , **/sales-receipts** , **/customers/\*\*** - PURCHASE: **/bills** , **/payments** , **/purchase-orders** , **/vendor-credits** , **/expenses** , **/landed-costs** , **/vendors/\*\*** - INVENTORY: **/items** , **/item-categories** , **/inventory** , **/settings/warehouses** , **/settings/units** , **/settings/price-lists** - BANKING: **/bank-transactions** , **/transfers** , **/reconciliation** - GL: **/accounts** , **/journal-entries** - PAYROLL: **/payroll/\*\*** , **/employees/\*\*** - FIN\_REPORTS: **/reports/\*\*** (P&L/BS/TB/CF/солиқ маршрутлари) - SETTINGS: **/settings** , **/settings/tax-rates** , **/settings/payment-methods** , **/settings/classes** , **/settings/import** , **/settings/reset** - USERS: **/users/\*\*** , **/audit-log/\*\***
- МАТЧЕР ТАРТИБИ КРИТИК:** **/settings/warehouses** (INVENTORY), **/settings/units** (INVENTORY), **/settings/price-lists** (INVENTORY) **/settings/\*\*** (SETTINGS) дан ОЛДИН ёзилиши шарт - акс ҳолда омбор менежери омбор каталогига кира олмайди ёки бутун **/settings** очилиб кетади. GET = VIEW, ёзувчи метод (POST) = EDIT текшируви.
2. **Метод даражасидаги гаров** (сезгир амаллар URL'дан ташқари ҳам): **@PreAuthorize** ёки service гарови - PERIOD\_CLOSE (closing date), factory reset, user create/update, роль тайинлаш. Сабаб: бир endpoint бир нечта амални бажарса, URL матчер етмайди.
3. **UI - тугма кўриниши** ( **canEdit** кенгайди): ягона boolean ўрнига соҳа флаглари ( **canWriteSales** , **canWritePurchase** , ...) ёки **perms** объекти. Сайдбар пунктлари ҳам соҳа бўйича кўринади (масалан SALES\_MANAGER'га «Харидлар» гуруҳи кўринмайди). VIEWER ҳозиргидек - ҳамма ёзув яширин. Server барибир ҳақиқат манбаи - UI фақат қулайлик.

Entity ва DB

- **AppUser.role** - битта устун қолади (VARCHAR(20), **011-app-user.sql** ). Enum қийматлари roles.md номларига ўзгаради; DB схемаси ЎЗГАРМАЙДИ (STRING enum, янги қиймат учун DDL керак эмас).
- **Permission матрица кодда** ( **RolePermissions** - **Map<UserRole, Set<Permission>>** ёки enum ичида) - DB жадвал йўқ (v1 қатъий тўплам). Spring Security'да роль → authority'лар (permission'лар) сифатида берилади ( **JwtUserDetailsService** кенгайди).
- **Changeset 052** (author averpo; 051 Arbitr-076 DB CHECK'ларга тақсимланган - арбитр) - фақат МАВЖУД маълумот миграцияси (схема эмас): **UPDATE app\_user SET role='SUPER\_ADMIN' WHERE role='ADMIN'; UPDATE app\_user SET role='ACCOUNTANT' WHERE role='ACCOUNTANT';** (ном сақланади) **UPDATE ... SET role='VIEWER\_AUDITOR' WHERE role='VIEWER';** . Rollback: тескари UPDATE'лар. Жонли серверда реал admin бор (миграция уни SUPER\_ADMIN қилади) - deploy'дан олдин текширилади.

Миграция (мавжуд 3 → янги 8)

| Эски       | Янги           | Изоҳ                                                                                |
|------------|----------------|-------------------------------------------------------------------------------------|
| ADMIN      | SUPER_ADMIN    | тўлиқ ҳуқуқ ўзгармайди                                                              |
| ACCOUNTANT | ACCOUNTANT     | ном сақланади, лекин рухсатлари энди GL/period close'сиз - CHIEF_ACCOUNTANT алоҳида |
| VIEWER     | VIEWER_AUDITOR | фақат кўриш ўзгармайди                                                              |

Эслатма: эски ACCOUNTANT кенг эди (ҳамма POST). Янги ACCOUNTANT'да JE/ period close/fin reports йўқ. Агар мавжуд ACCOUNTANT'лар бухгалтерия ядросида ишлаган бўлса - deploy дан кейин уларни CHIEF\_ACCOUNTANT'га кўтариш кераклиги фойдаланувчига эслатилади (миграция default'и ACCOUNTANT - хавфсиз томон, кам ҳуқуқ).

## BR каталоги (BR-USR кенгайиши)

Мавжуд BR-USR-001..010 сақланади. Янгилари (аввал docs/business-rules.md каталогига, кейин код - қоида 13):

- **BR-USR-011:** роль тайинлаш - фақат USERS EDIT рухсатли фойдаланувчи (амалда SUPER\_ADMIN) бошқа фойдаланувчига роль бера/ўзгартира олади.
- **BR-USR-012:** ўзига SUPER\_ADMIN'ни пасайтириш тақиқ (BR-USR-007 «охирги фаол admin» + ўз-ўзини блоклаш - SUPER\_ADMIN контекстида).

## Экранлар

- `/users/new` , `/users/{id}/edit` - роль select энди 8 вариант (i18n уч тил: `role.SUPER_ADMIN` ...). Ҳар роль ёнида қисқа тавсиф (масалан «Сотув - фақат мижоз ва сотув ҳужжатлари»).
- Сайдбар (main.jte) - гуруҳлар соҳа рухсати бўйича кўринади.
- Янги саҳифа ЙЎҚ - мавжуд экранлар рухсат бўйича филтрланади.

## Тестлар (мажбурий рўйхат)

1. `RolePermissions` матрица unit тести: ҳар роль учун кутилган соҳа даражалари (масалан SALES\_MANAGER'да PURCHASE=NONE, SALES=EDIT).
2. SecurityConfig integ тести (МУҲИМ - 054 сабоғи, MockMvc URL бўйича): - SALES\_MANAGER `/bills` POST → 403, `/invoices` POST → 200; - PURCHASE\_MANAGER `/invoices` POST → 403; - WAREHOUSE\_MANAGER `/settings/warehouses` → 200, `/settings` → 403 (матчер тартиби гарови); - ACCOUNTANT `/journal-entries` POST → 403 (GL йўқ); - VIEWER\_AUDITOR ҳар POST → 403, ҳар GET → 200.
3. PERIOD\_CLOSE: CHIEF closing date ўзгартиради → 200; ACCOUNTANT → 403.
4. Миграция: changeset 052 дан кейин эски роллар тўғри мапланади (ADMIN→SUPER\_ADMIN ва ҳ.к.) - интег ёки геро тести.
5. BR-USR-011/012: рухсатсиз роль тайинлаш рад; охирги SUPER\_ADMIN пасайтириш рад.
6. UI smoke: SALES\_MANAGER login → сайдбарда «Харидлар» йўқ, «Сотув» бор (ScreenSmoke ёки жонли).

## 2-босқич (ҳозир ЭМАС - алоҳида келишилади)

- **Per-user созланадиган доступ** (QBO Advanced услуги: ҳар фойдаланувчига соҳаларни ёқиш/ўчириш) - permission модели остида, DB `user_permission` жадвали билан.
- OPERATOR роли (UserRole изоҳидаги эски режа) - керак бўлса шу моделда янги тўплам сифатида қўшилади.

QBO'да ЙЎҚ нарсалар (CASHIER/POS, approval workflow, branch) 2-босқич рўйхатига ҲАМ кирмайди - «ОЛИБ ТАШЛАНДИ» бўлимига қаранг: улар фақат фойдаланувчи янги онгли фарқ деб қарор қилса қайтади (engineering-rules.md эталон қоидаси).